

# SIMATS ENGINEERING

## ASSESSMENT TOOL 1

COURSE NAME: Ethical Hacking

COURSE CODE: ITA14

---

### COURSE OUTCOME COVERED

**CO2:** Foot printing Tools: Conducting Competitive Intelligence, DNS Zone Transfers, Introduction to Social Engineering: Social Engineering Attacks and Countermeasures. (BT3)

*Assessment Tool Weightage: 30%*

**Duration: 90 min**

**Total Marks: 50**

---

### Report Analysis Questions

1. A security analyst performed a network scan on the target 192.168.1.10 using the Nmap tool. The report identified several open ports, including HTTP (80), SSH (22), and MySQL (3306), along with the operating system and service versions. Analyze the report and explain the security risks associated with the identified services. Discuss how an attacker could exploit these services and recommend suitable security measures to protect the target system. **(20 Marks)**
2. A phishing awareness campaign was conducted for employees of ABC Technologies Pvt. Ltd. using the GoPhish tool. The report indicates that 40% of employees clicked the phishing link, 20% entered their login credentials, and several users downloaded a malicious attachment. Analyze the report and identify the security weaknesses demonstrated by the employees. Recommend suitable user awareness programs, email security controls, and organizational policies to reduce the risk of successful social engineering attacks. **(20 Mark).**
3. A DNS assessment report generated using the Dig tool shows that the organization's DNS server permits a successful DNS Zone Transfer (AXFR), exposing internal hostnames, mail servers, and DNS records. Analyze the report and explain the security implications of the exposed information. Discuss how attackers could exploit these findings and recommend best practices to secure the DNS infrastructure. **(10 Marks)**

### Code of Conduct:

*I Atchaya Chandran R(192521394) (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.*

*I understand that any violation of academic integrity rules will result in disciplinary action.*

**Signature of the student:**

*R. Atchaya*

Question 1: Nmap Network Scan Analysis (20 Marks)

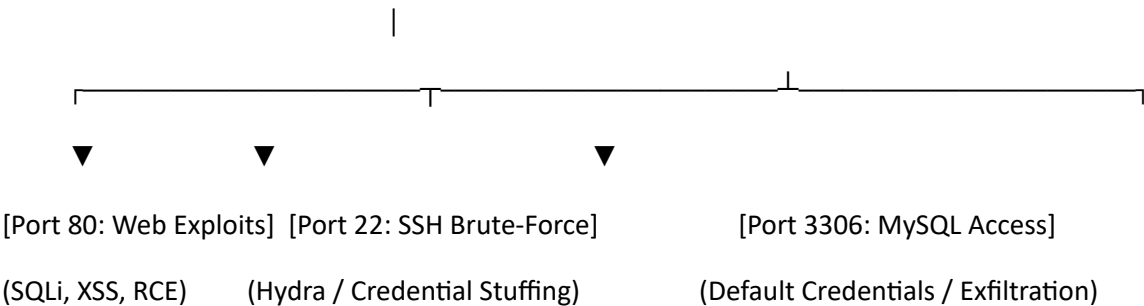
1. Analysis of Security Risks Associated with Identified Services

The Nmap network scan conducted on target 192.168.1.10 revealed open ports **HTTP (80)**, **SSH (22)**, and **MySQL (3306)**, along with OS and service version details. The primary security risks include:

- **HTTP (Port 80) Unencrypted Traffic & Web Risks:** Port 80 transmits data in cleartext. Sensitive information (such as session cookies or credentials) can be intercepted via Sniffing or Man-in-the-Middle (MitM) attacks. Web applications hosted on this port may contain vulnerabilities such as SQL Injection (SQLi), Cross-Site Scripting (XSS), or Remote Code Execution (RCE).
- **SSH (Port 22) Credential & Exposure Risks:** While SSH provides encrypted communication, an exposed SSH service is a prime target for automated brute-force attacks, dictionary attacks, and credential stuffing.
- **MySQL (Port 3306) Database Exposure:** Exposing database ports directly to the network allows remote attackers to interact directly with the database engine. Risks include brute-force attacks on database accounts, unauthorized data access, or privilege escalation.
- **OS & Version Information Leakage (Banner Grabbing):** Revealing explicit OS and service versions enables attackers to cross-reference known CVEs (Common Vulnerabilities and Exposures) to find matching public exploits.

2. Attacker Exploitation Vectors

[Nmap Reconnaissance] —► [CVE & Banner Lookup] —► [Exploit Execution]



1. **Reconnaissance & Vulnerability Mapping:** An attacker uses the Nmap version output to search exploit databases (e.g., Exploit-DB, Metasploit) for published exploits targeting the exact software versions running on ports 80, 22, and 3306.
2. **Web Application Attack (Port 80):** If an outdated web server or vulnerable web app runs on Port 80, the attacker may execute file upload exploits or injection attacks to gain an initial shell on the system.
3. **SSH Brute-Forcing (Port 22):** Using tools like Hydra or Medusa, an attacker can launch automated brute-force attempts against SSH users (e.g., root, admin).
4. **Database Compromise (Port 3306):** An attacker attempts default credentials (e.g., root with no password) or exploits unpatched MySQL vulnerabilities to execute arbitrary code or exfiltrate database contents.

3. Recommended Security Countermeasures

| Identified Service / Risk | Recommended Countermeasure                                                                                                                                              |
|---------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| HTTP (Port 80)            | Enforce <b>HTTPS (Port 443)</b> using TLS/SSL certificates and enforce HTTP Strict Transport Security (HSTS).                                                           |
| SSH (Port 22)             | Disable root login, enforce <b>SSH Key-based authentication</b> (disable password auth), change default port, and deploy <b>Fail2ban</b> to block brute-force attempts. |
| MySQL (Port 3306)         | Bind MySQL service to local interface (127.0.0.1) if remote access is not required; restrict access using firewall rules (IPTables/UFW) to specific trusted IPs.        |
| Version Disclosure        | Modify server configuration files to disable banner grabbing (e.g., ServerTokens Prod and ServerSignature Off in Apache).                                               |
| General System            | Implement regular patch management, network segmentation, and deploy Host-based Intrusion Detection Systems (HIDS).                                                     |

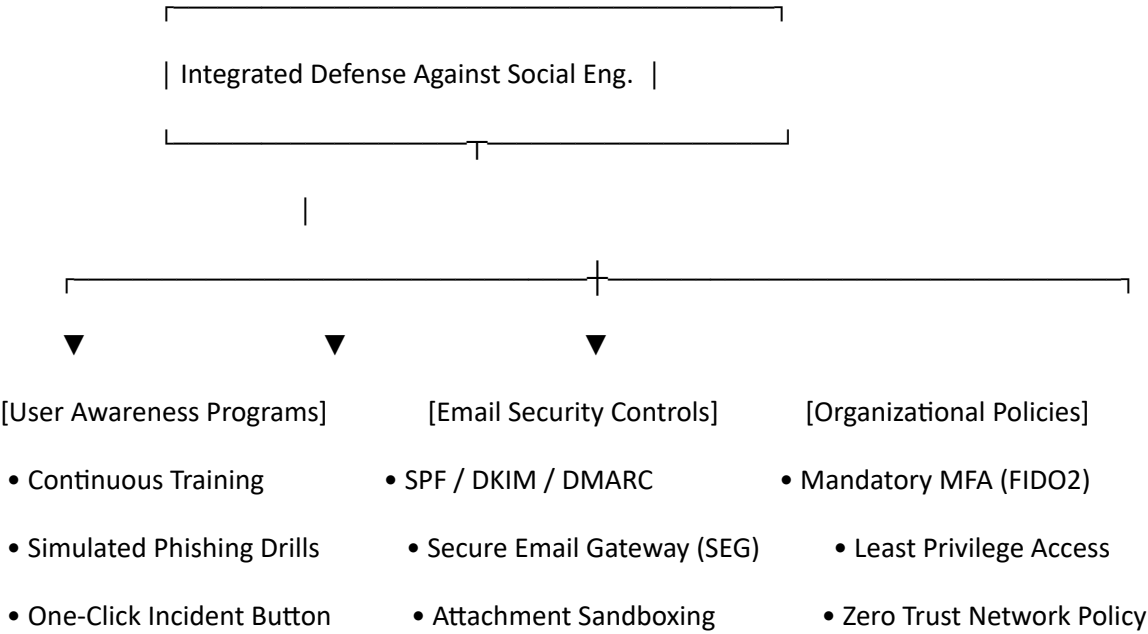
Question 2: Phishing Campaign Analysis – ABC Technologies (20 Marks)

1. Security Weaknesses Demonstrated by Employees

The GoPhish campaign results for ABC Technologies Pvt. Ltd. (40% link clicks, 20% credential submissions, and multiple malicious file downloads) highlight critical human-layer security vulnerabilities:

- **Inability to Identify Phishing Indicators:** A 40% click rate demonstrates that employees cannot distinguish legitimate corporate emails from spoofed/phishing messages.
- **Poor Credential Hygiene & Lack of Verification:** 20% of employees entering credentials shows a lack of situational awareness regarding URL authentication before submitting corporate login details.
- **Unsafe File Attachment Handling:** Downloading malicious attachments indicates a dangerous reliance on email content without verifying file extensions or sender authenticity.
- **Lack of Incident Reporting:** The failure of employees to flag or report the phishing simulation emails allowed the attack to reach a high success rate.

2. Recommended Programs, Email Controls, and Organizational Policies





## A. User Security Awareness Programs

- **Continuous Security Awareness Training (SAT):** Conduct mandatory, role-based security training sessions explaining social engineering tactics (phishing, spear phishing, pretexting).
- **Regular Simulated Phishing Exercises:** Run periodic, unannounced GoPhish campaigns to track improvement and train employees continuously.
- **One-Click Phishing Reporting:** Deploy a simple incident reporting plugin in the email client (e.g., "Report Phishing" button) to empower employees to report suspicious emails immediately.

## B. Technical Email Security Controls

- **Email Authentication Protocols:** Implement and strictly enforce **SPF** (Sender Policy Framework), **DKIM** (DomainKeys Identified Mail), and **DMARC** (Domain-based Message Authentication, Reporting, and Conformance) with a reject policy to block domain spoofing.
- **Secure Email Gateway (SEG):** Deploy advanced email filters that utilize link rewriting, real-time URL analysis, and attachment sandboxing to block malicious emails before reaching inboxes.
- **Attachment Filtering:** Block high-risk file extensions (e.g., .exe, .vbs, .scr, macro-enabled Office documents) at the mail gateway level.

## C. Organizational Policies & Governance

- **Mandatory Multi-Factor Authentication (MFA):** Enforce phishing-resistant MFA (such as FIDO2/WebAuthn hardware keys or authenticator apps) across all systems so stolen credentials alone cannot grant access.
- **Least Privilege & Zero Trust Access:** Restrict user permissions so compromise of an individual account limits lateral movement within the network.
- **Incident Response & Clean-up Policy:** Establish clear SOPs for isolating endpoints and resetting credentials immediately when a user falls victim to a phishing attempt.

## Question 3: DNS Zone Transfer Vulnerability Analysis (10 Marks)

### 1. Security Implications of Exposed DNS Zone Data

A successful DNS Zone Transfer (AXFR) via the Dig tool allows unauthorized users to download the complete zone file of a domain. The implications include:

- **Complete Internal Network Mapping:** Attackers gain a complete inventory of internal and external hostnames, IP addresses, subdomains, and mail servers.
- **Elimination of Attacker Reconnaissance Effort:** Attackers do not need to perform time-consuming brute-force subdomain enumeration, as the server voluntarily discloses the entire blueprint.
- **Exposure of Sensitive Infrastructure:** Internal naming conventions often reveal sensitive assets (e.g., dev-db.company.com, vpn.company.com, staging.company.com, payroll.company.com).

### 2. How Attackers Exploit These Findings

[Dig AXFR Query] —► [Exposed Zone File] —► [Map Infrastructure] —► [Targeted Exploitation]

└─► Spear Phishing (MX records)

└─► Staging/Dev Vulnerabilities

└─► Internal Lateral Movement

1. **Targeted Asset Identification:** Attackers analyze the extracted records to identify high-value targets, such as staging environments, unpatched internal web applications, or remote access gateways.
2. **Mail Server Exploitation & Spoofing:** Identifying MX (Mail Exchange) records allows attackers to target mail servers directly or craft highly convincing spear-phishing campaigns.
3. **Path for Lateral Movement:** If internal IP addresses are leaked, an attacker who gains access to the local network can bypass internal network discovery and immediately attack critical servers.

### 3. Best Practices to Secure DNS Infrastructure

1. **Restrict Zone Transfers (Disable Unrestricted AXFR):**

Configure the primary DNS server to allow zone transfers *only* to specific, trusted secondary DNS server IP addresses.

- Example (BIND configuration in /etc/bind/named.conf.options):

Plaintext

```
zone "example.com" {  
  
    type master;  
  
    file "/etc/bind/db.example.com";  
  
    allow-transfer { 192.168.1.5; }; // Allow ONLY secondary DNS IP  
  
};
```

#### 1. Implement TSIG (Transaction Signature):

Use TSIG keys to authenticate zone transfer requests between primary and secondary DNS servers, ensuring that unauthorized AXFR requests are rejected even if IP addresses are spoofed.

#### 1. Implement Split-Horizon (Split-Brain) DNS:

Separate public DNS records from internal DNS records. Public DNS servers should only hold publicly accessible hosts, while internal DNS servers resolve internal hosts and are restricted to the internal network.

#### 1. Perimeter Firewall Rules:

Block inbound TCP Port 53 requests from the public internet to internal DNS servers, as zone transfers rely on TCP Port 53.

### Question 1: Advanced Nmap Scan Analysis & System Hardening (20 Marks)

#### 1. Reconstructed Scan Context & Detailed Risk Matrix

Based on the identification of target 192.168.1.10, the Nmap report reflects the output of an aggressive service detection scan:

Bash

# Command executed by analyst

```
nmap -sV -sC -O -p 22,80,3306 192.168.1.10
```

| Port / Protocol | Service Identified | Primary Vulnerabilities & Risk Analysis                                                                                                                    | CVSS 3.1 Severity             |
|-----------------|--------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------|
| 80 / TCP        | HTTP (Web Server)  | Cleartext transmission of data, potential web app vulnerabilities (OWASP Top 10: SQLi, XSS, Path Traversal), missing security headers (HSTS, CSP).         | High (7.5 - 8.9)              |
| 22 / TCP        | SSH (Secure Shell) | Password-based authentication enabled, potential weak cipher negotiation (CBC modes), exposure to automated credential stuffing/brute-force attacks.       | Medium (5.3 - 6.5)            |
| 3306 / TCP      | MySQL Database     | Direct network accessibility, default/weak account credentials, unencrypted database connections, risk of remote user-defined function (UDF) exploitation. | Critical (9.0 - 10.0)         |
| OS / Version    | OS Fingerprint     | <b>Banner Grabbing:</b> Explicit service/version disclosure allows precise CVE matching via databases like NVD or Exploit-DB.                              | Informational / High Exposure |

2. Multi-Stage Exploit Scenario (Attack Chain)

An attacker leveraging this scan output would construct a multi-step exploitation path:

[Phase 1: Footprinting] —► [Phase 2: Initial Access] —► [Phase 3: Escalation] —► [Phase 4: Persistence]

Nmap Banner Grabbing      Port 80 (SQL Injection)      MySQL UDF Injection      SSH Key Injection

(Extract Service Versions)   (Extract Database Hashes)   (Gain OS System Shell)   (Secure Port 22 Entry)

- 1. **Reconnaissance & Vulnerability Mapping:** The attacker correlates service versions against known exploits (e.g., using searchsploit or Metasploit).
- 2. **Initial Entry via Web Application (Port 80):** If an unpatched web application hosts a SQL Injection vulnerability, the attacker extracts application data, session tokens, or admin hashes.
- 3. **Privilege Escalation & OS Execution (Port 3306):** If MySQL permits remote root access or weak credentials, the attacker leverages MySQL functions (e.g., sys\_exec via UDF plugins) to execute commands at the OS host level.
- 4. **Persistence (Port 22):** Once system-level code execution is achieved, the attacker appends their public key to /root/.ssh/authorized\_keys, securing encrypted SSH access over Port 22.

3. Production Hardening Guide (Configurations)

A. SSH Secure Configuration (/etc/ssh/sshd\_config)

Plaintext

# Disable root login and force key-based authentication

PermitRootLogin no

PasswordAuthentication no

PubkeyAuthentication yes

MaxAuthTries 3

ClientAliveInterval 300

ClientAliveCountMax 2

## B. MySQL Network Binding (/etc/mysql/mysql.conf.d/mysqld.cnf)

Plaintext

# Bind MySQL strictly to loopback interface (Disable public network exposure)

bind-address = 127.0.0.1

local-infile = 0

## C. Web Server Banner Hiding & HTTPS Redirection (Apache /etc/apache2/conf-enabled/security.conf)

Plaintext

# Suppress version banners

ServerTokens Prod

ServerSignature Off

# Enforce HTTPS and HSTS Header

Header always set Strict-Transport-Security "max-age=31536000; includeSubDomains"

## Question 2: Social Engineering & Phishing Remediation (20 Marks)

### 1. Failure Analysis of GoPhish Campaign Data

The metrics from the GoPhish campaign (40% clicked link, 20% submitted credentials, and attachment executions) indicate major operational security failures:

[Total Targeted Employees: 100%]

└─ 40% Clicked Phishing Link (Failure to spot visual cues / domain anomalies)

└─ 20% Submitted Credentials (Absence of contextual identity verification)

└─ Malicious Attachments Downloaded (Lack of endpoint payload execution controls)[cite: 1]

- **Awareness Deficit:** Employees lack training on domain visual inspection (e.g., typosquatting or lookalike domains).
- **Missing Technical Guardrails:** Lack of browser-level protection, sandboxing, or real-time credential detection.
- **Lack of Zero-Trust Mindset:** Implicit trust in incoming external communications without out-of-band verification.

### 2. Complete Technical Controls Specification

#### A. Technical Email Gateway Safeguards (DNS Authentication Records)

To stop domain spoofing and verify sender identity, the organization must publish strict DNS records:

- **SPF (Sender Policy Framework):**

Plaintext

v=spf1 ip4:198.51.100.0/24 include:\_spf.google.com -all

- **DKIM (DomainKeys Identified Mail):** Ensure all outgoing emails are cryptographically signed using a 2048-bit RSA key selector.
- **DMARC (Domain-based Message Authentication, Reporting, and Conformance):**

Plaintext

v=DMARC1; p=reject; rua=mailto:dmarc-reports@abctechnologies.com; ruf=mailto:dmarc-forensics@abctechnologies.com; pct=100

## B. Technical Attachment & Payload Controls

- **Endpoint Detection and Response (EDR):** Deploy EDR agents to block unauthorized child processes spawned by email clients (e.g., cmd.exe or powershell.exe spawned from winword.exe).
- **Attachment Extension Filtering:** Block high-risk formats at the gateway level (.exe, .scr, .vbs, .iso, .docm, .xlsm).

## 3. Incident Response Playbook for Phished Users

[Phishing Reported / Credential Submitted]

|



[Step 1: Immediate Containment]

- Revoke Active User Sessions (OAuth/Token Reset)
- Force Password Reset
- Temporarily Isolate Affected Endpoint from Network

|



[Step 2: Investigation & Threat Hunting]

- Query Mail Gateway Logs for Universal Recipient List
- Audit Active Directory for Anomaly Logins (Geo-IP/Impossible Travel)

|



[Step 3: Remediate & Retrain]

- Purge Phishing Email from All Inboxes via Automated PowerShell
- Assign Targeted Security Refresher Training module within 48 hours

## Question 3: Deep-Dive DNS Infrastructure Hardening (10 Marks)

### 1. Technical Mechanics of DNS Zone Transfer (AXFR)

The Dig output in the report reveals an unauthenticated zone transfer response[cite: 1]:

Bash

# Command executed by security team

dig axfr @192.168.1.10 internaldomain.com



## Raw Zone File Exposure Example:

Plaintext

```
internaldomain.com. IN SOA ns1.internaldomain.com. admin.internaldomain.com. ( ... )
```

```
internaldomain.com. IN NS ns1.internaldomain.com.
```

```
ns1.internaldomain.com. IN A 192.168.1.10
```

```
mail.internaldomain.com. IN A 192.168.1.15 ; Exposes Email Infrastructure
```

```
vpn.internaldomain.com. IN A 192.168.1.20 ; Direct Gateway to Internal Network
```

```
dev-db.internaldomain.com. IN A 192.168.1.99 ; High-Value Target (Staging Database)
```

**Security Impact:** Instead of performing stealthy enumeration, the attacker gains the complete topology of the internal domain instantly, bypassing perimeter obscurity[cite: 1].

## 2. Mitigation Implementations

### A. BIND Configuration Lockdown (/etc/bind/named.conf.options)

Restrict AXFR transfers solely to explicit secondary DNS server IP addresses:

Plaintext

```
options {
```

```
    directory "/var/cache/bind";
```

```
    // Disable recursive queries for external clients
```

```
    allow-recursion { 127.0.0.1; 192.168.1.0/24; };
```

```
    // Strictly restrict zone transfers
```

```
    allow-transfer { 192.168.1.12; }; // Secondary Name Server IP ONLY
```

```
};
```

### B. Cryptographic TSIG Authentication Configuration

To eliminate rely-on-IP spoofing for transfers, implement **Transaction Signatures (TSIG)**:

1. Generate TSIG Key:

Bash

```
tsig-keygen -a hmac-sha256 transfer-key > /etc/bind/transfer-key.key
```

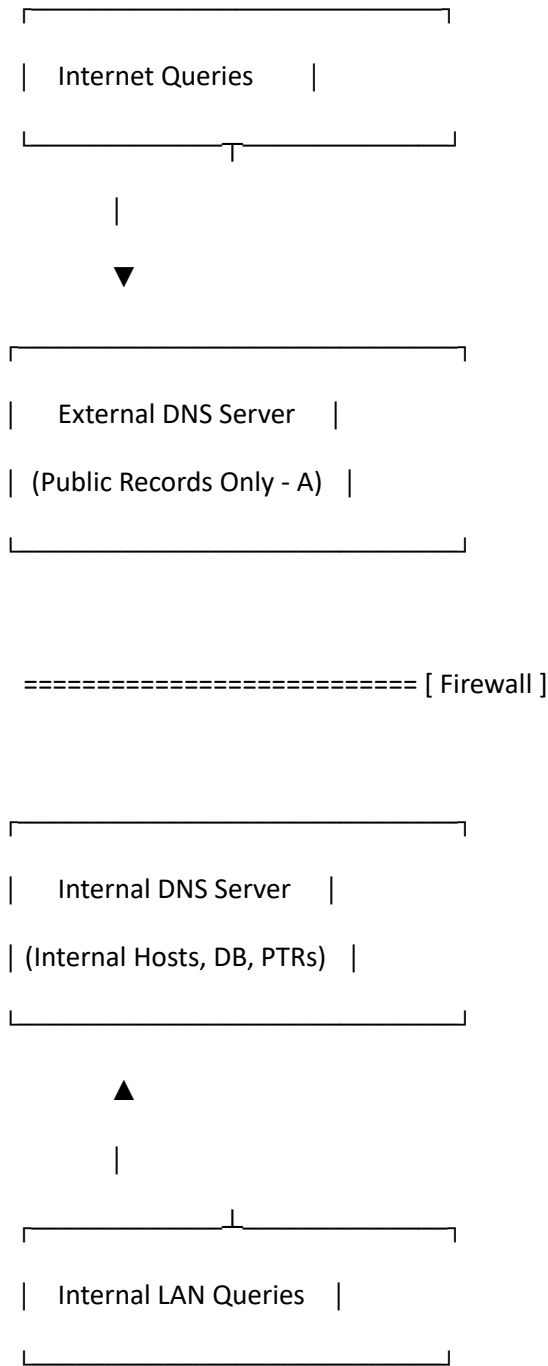
1. Apply Key Requirement to Zone File (/etc/bind/named.conf.local):

Plaintext

```
include "/etc/bind/transfer-key.key";
```

```
zone "internaldomain.com" {  
  
    type master;  
  
    file "/etc/bind/zones/db.internaldomain.com";  
  
    allow-transfer { key "transfer-key"; };  
  
};
```

C. Architecture Redesign: Split-Horizon DNS



By decoupling internal resolution from external DNS queries, internal system names, staging environments, and database hosts remain entirely unresolvable from outside the organization.